

Technical Security Assessment Report

Target: 127.0.0.1 | Scan #4 | 2026-10-08 15:49:00 UTC | Profile: standard | Operator: operator

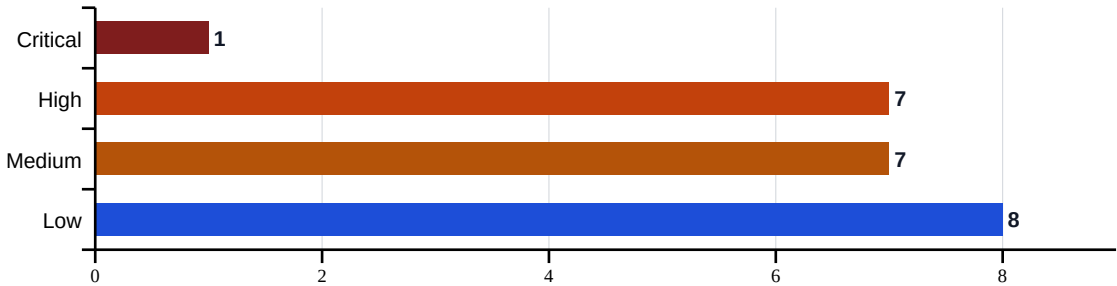
1	4	23	0	0	63
Assets	Open services	Findings	Unique CVEs	CISA KEV	Risk index

1. Scope and methodology

Target scope	127.0.0.1
Authorization	Target within configured scope file
Start / duration	2026-10-08T15:48:26+00:00 UTC / 34.1s
Scanner	Nmap 7.94SVN (privileged)
Nmap arguments	-oX - --stats-every 3s --reason -T4 -Pn -sS -p 2121,6379,8080,8443 -sV --script banner,http-title,http-server-header,ssl-cert,ftp-anon,smb2-security-mode,smb-protocols,dns-recursion,redis-info 127.0.0.1
Checks performed	port & service discovery, service/version detection, safe NSE scripts, TLS certificate & protocol checks, passive web checks, NVD CVE correlation + FIRST EPSS + CISA KEV
Risk model	Base CVSS (or ENSAT rule score) adjusted for CISA KEV, EPSS, public exploits, internet exposure, asset criticality and business impact. Critical >= 9.0, High >= 7.0, Medium >= 4.0, Low > 0.
Limitations	CVE lookup skipped: NVD unreachable: HTTPConnectionPool(host='services.nvd.nist.gov', port=443): Max retries exceeded with url: /rest/json/cves/2.0?cpeName=cpe%3A2.3%3Aa%3Aredislabs%3Aredis%3A7.0.15%3A%2A%3A%2A%3A%2A%3A%2A%3A%2A%3A%2A&resultsPerPage=200 (Caused by ProxyError('Unable to connect to proxy', OSError('Tunnel connection failed: 403 Forbidden')))

2. Risk summary

1 critical vulnerability requires immediate remediation, followed by 7 high-risk issues.



3. Asset inventory

Address	Hostname	OS	MAC / vendor	Crit.	Risk	C/H/M/L
127.0.0.1	localhost			Medium	9.0	1/7/7/8

4. Service inventory

Host	Port	Service	Product / version	Notes
127.0.0.1	2121/tcp	ftp	pyftplib 2.2.0	cpe:/a:giampaolo_rodola:pyftplib
127.0.0.1	6379/tcp	redis	Redis key-value store 7.0.15 64 bits	cpe:/a:redislabs:redis:7.0.15 cpe:/a:redis:redis:7.0.15
127.0.0.1	8080/tcp	http	SimpleHTTPServer 0.6 Python 3.13.16	Title: Lab; cpe:/a:python:simplehttpserver:0.6
127.0.0.1	8443/tcp	http	SimpleHTTPServer 0.6 Python 3.13.16	TLS cert until 2026-10-03 (lab.local); Title: Lab; cpe:/a:python:simplehttpserver:0.6 cpe:/a:php:php:7.2.1

5. Detailed findings

1. CRITICAL 9.0 Redis accepts unauthenticated commands	
Asset / service	127.0.0.1:6379/tcp redis
Status	IN_PROGRESS (first seen 2026-10-08, ID 24ec145214)
OWASP	A07:2021 Identification and Authentication Failures
Risk calculation	Base 9.0 (ENSAT rule)
Evidence	Version: 7.0.15 Operating System: Linux 6.18.44-fc-v80 x86_64 Architecture: 64 bits Process ID: 984 Used CPU (sys): 0.237286 Used CPU (user): 0.275734 Connected clients: 2 Connected slaves: 0 Used memory: 1.01M Role: master Bind addresses: * -::* Client connections:
Impact	Unauthenticated Redis can be used to read/write data and often to execute code on the host.
Recommendation	Enable requirepass/ACLs and protected-mode; bind to localhost.
2. HIGH 8.5 Redis exposed	
Asset / service	127.0.0.1:6379/tcp redis
Status	OPEN (first seen 2026-10-08, ID 4d961c63b3)
OWASP	A05:2021 Security Misconfiguration
Risk calculation	Base 8.5 (ENSAT rule)
Evidence	TCP/6379 redis Redis key-value store 7.0.15 64 bits
Impact	Redis is often deployed without authentication and can be abused for remote code execution.
Recommendation	Bind Redis to localhost/internal networks, enable protected-mode and requirepass/ACLs.
3. HIGH 8.0 Environment file exposed (/env)	
Asset / service	127.0.0.1:8080/tcp http
Status	OPEN (first seen 2026-10-08, ID 12dfb85e3e)
OWASP	A05:2021 Security Misconfiguration
Risk calculation	Base 8.0 (ENSAT rule)
Evidence	GET http://127.0.0.1:8080/.env -> HTTP 200
Impact	Environment files typically contain database passwords and API keys.
Recommendation	Remove .env from the web root, deny dot-files in the web server, and rotate any exposed secrets.
4. HIGH 8.0 Environment file exposed (/env)	
Asset / service	127.0.0.1:8443/tcp http
Status	OPEN (first seen 2026-10-08, ID b372ab72a7)
OWASP	A05:2021 Security Misconfiguration
Risk calculation	Base 8.0 (ENSAT rule)
Evidence	GET https://127.0.0.1:8443/.env -> HTTP 200
Impact	Environment files typically contain database passwords and API keys.
Recommendation	Remove .env from the web root, deny dot-files in the web server, and rotate any exposed secrets.

5. HIGH 7.5 Anonymous FTP login allowed	
Asset / service	127.0.0.1:2121/tcp ftp
Status	OPEN (first seen 2026-10-08, ID 0034a2fd70)
OWASP	A05:2021 Security Misconfiguration
Risk calculation	Base 7.5 (ENSAT rule)
Evidence	Anonymous FTP login allowed (FTP code 230)
Impact	Anyone can log in without credentials and read (possibly write) files.
Recommendation	Disable anonymous access (anonymous_enable=NO) unless the server is an intentional public mirror.

6. HIGH 7.5 Git repository exposed (/git/)	
Asset / service	127.0.0.1:8080/tcp http
Status	OPEN (first seen 2026-10-08, ID 5b899fcbec)
OWASP	A05:2021 Security Misconfiguration
Risk calculation	Base 7.5 (ENSAT rule)
Evidence	GET http://127.0.0.1:8080/.git/HEAD -> HTTP 200
Impact	Source code, history and embedded secrets can be downloaded.
Recommendation	Block access to /git/ in the web server and remove the directory from the web root.

7. HIGH 7.5 Git repository exposed (/git/)	
Asset / service	127.0.0.1:8443/tcp http
Status	OPEN (first seen 2026-10-08, ID 4ec6dcd46b)
OWASP	A05:2021 Security Misconfiguration
Risk calculation	Base 7.5 (ENSAT rule)
Evidence	GET https://127.0.0.1:8443/.git/HEAD -> HTTP 200
Impact	Source code, history and embedded secrets can be downloaded.
Recommendation	Block access to /git/ in the web server and remove the directory from the web root.

8. HIGH 7.0 Weak certificate key	
Asset / service	127.0.0.1:8443/tcp http
Status	OPEN (first seen 2026-10-08, ID c50ca4ac14)
OWASP	A02:2021 Cryptographic Failures
Risk calculation	Base 7.0 (ENSAT rule)
Evidence	Subject: lab.local; Issuer: lab.local; Valid until: 2026-10-03; Key: RSA 1024
Impact	Short RSA or DSA keys can be factored or are deprecated.
Recommendation	Reissue the certificate with RSA >= 2048 bits or an ECDSA P-256 key.

9. MEDIUM 6.5 FTP service exposed	
Asset / service	127.0.0.1:2121/tcp ftp
Status	OPEN (first seen 2026-10-08, ID 32d24584fa)
OWASP	A02:2021 Cryptographic Failures
Risk calculation	Base 6.5 (ENSAT rule)
Evidence	TCP/2121 ftp pyftplib 2.2.0
Impact	FTP sends credentials and files unencrypted.
Recommendation	Replace FTP with SFTP/FTPS or restrict it to a trusted management network.

10. MEDIUM 6.5 TLS certificate has expired	
Asset / service	127.0.0.1:8443/tcp http
Status	OPEN (first seen 2026-10-08, ID 908c31502d)
OWASP	A02:2021 Cryptographic Failures
Risk calculation	Base 6.5 (ENSAT rule)
Evidence	Subject: lab.local; Issuer: lab.local; Valid until: 2026-10-03; Key: RSA 1024 (expired 5 days ago)
Impact	Clients will show security warnings; users learn to click through them, enabling interception.
Recommendation	Renew the certificate and automate renewal (e.g. ACME/Let's Encrypt or your internal CA).
11. MEDIUM 6.5 Deprecated TLS/SSL protocol versions enabled	
Asset / service	127.0.0.1:8443/tcp http
Status	OPEN (first seen 2026-10-08, ID 1492926bc7)
OWASP	A02:2021 Cryptographic Failures
Risk calculation	Base 6.5 (ENSAT rule)
Evidence	Server accepts: TLSv1.0, TLSv1.1
Impact	SSLv3/TLS 1.0/TLS 1.1 are deprecated (RFC 8996) and vulnerable to downgrade and padding-oracle attacks.
Recommendation	Allow only TLS 1.2 and TLS 1.3.
12. MEDIUM 5.0 Web service does not enforce HTTPS	
Asset / service	127.0.0.1:8080/tcp http
Status	OPEN (first seen 2026-10-08, ID 0da6071a69)
OWASP	A02:2021 Cryptographic Failures
Risk calculation	Base 5.0 (ENSAT rule)
Evidence	http://127.0.0.1:8080/ answered HTTP 200 without redirecting to HTTPS
Impact	Traffic, sessions and credentials can be intercepted or modified in transit.
Recommendation	Serve the site over HTTPS and redirect all HTTP requests (301) to HTTPS.
13. MEDIUM 5.0 Self-signed TLS certificate	
Asset / service	127.0.0.1:8443/tcp http
Status	OPEN (first seen 2026-10-08, ID 25ee9f5698)
OWASP	A02:2021 Cryptographic Failures
Risk calculation	Base 5.0 (ENSAT rule)
Evidence	Subject: lab.local; Issuer: lab.local; Valid until: 2026-10-03; Key: RSA 1024
Impact	Clients cannot verify the server's identity, which permits man-in-the-middle attacks.
Recommendation	Use a certificate issued by a trusted public or internal CA.
14. MEDIUM 4.0 HSTS header missing	
Asset / service	127.0.0.1:8443/tcp http
Status	OPEN (first seen 2026-10-08, ID 172816f733)
OWASP	A05:2021 Security Misconfiguration
Risk calculation	Base 4.0 (ENSAT rule)
Evidence	https://127.0.0.1:8443/ has no Strict-Transport-Security header
Impact	Browsers can be downgraded to HTTP by an attacker on the network (SSL stripping).
Recommendation	Add 'Strict-Transport-Security: max-age=31536000; includeSubDomains'.

15. MEDIUM 4.0 Cookies set without security attributes	
Asset / service	127.0.0.1:8443/tcp http
Status	OPEN (first seen 2026-10-08, ID 3f2645e749)
OWASP	A07:2021 Identification and Authentication Failures
Risk calculation	Base 4.0 (ENSAT rule)
Evidence	SESSIONID (missing Secure, HttpOnly, SameSite)
Impact	Session cookies may be stolen via XSS, sent over HTTP or used in cross-site requests.
Recommendation	Set Secure, HttpOnly and SameSite on session cookies.
16. LOW 3.5 Content-Security-Policy header missing	
Asset / service	127.0.0.1:8080/tcp http
Status	OPEN (first seen 2026-10-08, ID 8a319cc57d)
OWASP	A03:2021 Injection
Risk calculation	Base 3.5 (ENSAT rule)
Evidence	http://127.0.0.1:8080/: no CSP header
Impact	Without CSP, cross-site scripting flaws are easier to exploit.
Recommendation	Define a Content-Security-Policy that restricts script sources.
17. LOW 3.5 No clickjacking protection	
Asset / service	127.0.0.1:8080/tcp http
Status	OPEN (first seen 2026-10-08, ID 0ec6f362ed)
OWASP	A05:2021 Security Misconfiguration
Risk calculation	Base 3.5 (ENSAT rule)
Evidence	http://127.0.0.1:8080/: neither X-Frame-Options nor CSP frame-ancestors set
Impact	The site can be framed by a malicious page to trick users into clicking (clickjacking).
Recommendation	Send 'X-Frame-Options: DENY' or a CSP 'frame-ancestors' directive.
18. LOW 3.5 Content-Security-Policy header missing	
Asset / service	127.0.0.1:8443/tcp http
Status	OPEN (first seen 2026-10-08, ID 6a4f392bf9)
OWASP	A03:2021 Injection
Risk calculation	Base 3.5 (ENSAT rule)
Evidence	https://127.0.0.1:8443/: no CSP header
Impact	Without CSP, cross-site scripting flaws are easier to exploit.
Recommendation	Define a Content-Security-Policy that restricts script sources.
19. LOW 3.5 No clickjacking protection	
Asset / service	127.0.0.1:8443/tcp http
Status	OPEN (first seen 2026-10-08, ID 86ebe652f3)
OWASP	A05:2021 Security Misconfiguration
Risk calculation	Base 3.5 (ENSAT rule)
Evidence	https://127.0.0.1:8443/: neither X-Frame-Options nor CSP frame-ancestors set
Impact	The site can be framed by a malicious page to trick users into clicking (clickjacking).
Recommendation	Send 'X-Frame-Options: DENY' or a CSP 'frame-ancestors' directive.

20. LOW 3.0 Web server discloses software versions	
Asset / service	127.0.0.1:8080/tcp http
Status	OPEN (first seen 2026-10-08, ID 2e1559ce0d)
OWASP	A05:2021 Security Misconfiguration
Risk calculation	Base 3.0 (ENSAT rule)
Evidence	Server: SimpleHTTP/0.6 Python/3.13.16
Impact	Exact versions help attackers pick matching exploits.
Recommendation	Suppress version banners (e.g. ServerTokens Prod, server_tokens off, remove X-Powered-By).
21. LOW 3.0 Web server discloses software versions	
Asset / service	127.0.0.1:8443/tcp http
Status	OPEN (first seen 2026-10-08, ID 4f1bdf8176)
OWASP	A05:2021 Security Misconfiguration
Risk calculation	Base 3.0 (ENSAT rule)
Evidence	Server: SimpleHTTP/0.6 Python/3.13.16; X-Powered-By: PHP/7.2.1
Impact	Exact versions help attackers pick matching exploits.
Recommendation	Suppress version banners (e.g. ServerTokens Prod, server_tokens off, remove X-Powered-By).
22. LOW 2.5 Recommended security headers missing	
Asset / service	127.0.0.1:8080/tcp http
Status	OPEN (first seen 2026-10-08, ID db0d8ae4d0)
OWASP	A05:2021 Security Misconfiguration
Risk calculation	Base 2.5 (ENSAT rule)
Evidence	http://127.0.0.1:8080/ missing: X-Content-Type-Options, Referrer-Policy, Permissions-Policy
Impact	Missing hardening headers weaken browser-side defences (MIME sniffing, referrer leakage).
Recommendation	Add X-Content-Type-Options: nosniff, a Referrer-Policy and a Permissions-Policy.
23. LOW 2.5 Recommended security headers missing	
Asset / service	127.0.0.1:8443/tcp http
Status	OPEN (first seen 2026-10-08, ID 54f0d8e6ae)
OWASP	A05:2021 Security Misconfiguration
Risk calculation	Base 2.5 (ENSAT rule)
Evidence	https://127.0.0.1:8443/ missing: X-Content-Type-Options, Referrer-Policy, Permissions-Policy
Impact	Missing hardening headers weaken browser-side defences (MIME sniffing, referrer leakage).
Recommendation	Add X-Content-Type-Options: nosniff, a Referrer-Policy and a Permissions-Policy.
24. INFO 0.0 Web technology fingerprint	
Asset / service	127.0.0.1:8080/tcp http
Status	OPEN (first seen 2026-10-08, ID f0e2bd268f)
Risk calculation	Base 0.0 (ENSAT rule); Informational finding
Evidence	Server: SimpleHTTP/0.6 Python/3.13.16
Impact	Informational: technologies identified on the site.
Recommendation	Keep the listed components patched and track them in your software inventory.

25. INFO 0.0 Web technology fingerprint	
Asset / service	127.0.0.1:8443/tcp http
Status	OPEN (first seen 2026-10-08, ID 8050cae62e)
Risk calculation	Base 0.0 (ENSAT rule); Informational finding
Evidence	Server: SimpleHTTP/0.6 Python/3.13.16; X-Powered-By: PHP/7.2.1
Impact	Informational: technologies identified on the site.
Recommendation	Keep the listed components patched and track them in your software inventory.

Appendix: status workflow

OPEN → IN_PROGRESS → REMEDIATED → VERIFIED. ENSAT marks a REMEDIATED issue as VERIFIED automatically when a later scan of the same scope no longer detects it, and reopens it if it reappears. ACCEPTED_RISK and FALSE_POSITIVE are analyst decisions and are never changed automatically.